

MOINA

관리자 가이드

linux/amd64 단일 컨테이너 · 외부 PostgreSQL · 폐쇄망 운영

버전	v0.1.31
작성일	2026-09-17
문서	관리자 가이드

MOINA 관리자 가이드

버전 `v0.1.31` · linux/amd64 단일 컨테이너 · 외부 PostgreSQL · 폐쇄망 운영

이 문서는 MOINA를 설치하고 지키는 사람을 위한 안내입니다. 화면을 쓰는 방법은 [사용자 가이드](#)에 있으니 사용자에게는 그 문서를 안내하세요.

이 문서의 화면 캡처는 `v0.1.31` 서비스를 실제로 띄워 캡처 전용 데이터베이스에서 찍은 것이며, 화면에 보이는 계정·주소는 모두 예시입니다.

1. 구성 요소

구성	내용
서비스 컨테이너	<code>moina:v0.1.31</code> 하나. <code>distroless·non-root·read-only</code> 로 실행하며 Go 서버와 React 웹 앱을 함께 담고 있습니다.
데이터 저장소	외부 PostgreSQL . 이미지에 포함되지 않으므로 기관 표준 PostgreSQL을 먼저 준비합니다. 미디어는 Large Object로 저장합니다.
노출 포트	컨테이너 <code>8080</code> (HTTP). 기본 <code>compose</code> 는 <code>127.0.0.1:8080</code> 에만 bind합니다.
앞단	기관 표준 TLS reverse proxy. WebSocket과 SSE를 통과시켜야 합니다.
선택 연동	Keycloak 등 OIDC Provider, OpenAI 호환 AI endpoint, SMTP 메일 서버. 모두 관리 화면에서 켜고 끕니다.
관측	<code>GET /metrics</code> (Prometheus text), 구조화 JSON 로그, 응답의 <code>X-Request-ID</code>

브라우저 런타임은 외부 CDN·웹 폰트·분석 스크립트를 쓰지 않고, 완성된 이미지는 registry나 package repository에 접근하지 않습니다. 선택 연동은 폐쇄망 안에서 도달할 수 있는 내부 endpoint여야 합니다.

자원은 최소 2 CPU·2 GiB RAM과 시간 동기화된 linux/amd64 호스트를 권장합니다. 컨테이너 자체는 `/tmp`만 쓰므로 별도 볼륨이 필요 없고, 보존해야 하는 상태는 전부 PostgreSQL에 있습니다.

배포 전 점검

항목	확인할 것
Container runtime	Docker 24+ 또는 호환 runtime, Compose v2
PostgreSQL	전용 database·user, UTF-8, TLS, migration 권한, pg_trgm 생성 권한, backup에 Large Object 포함
TLS	reverse proxy에서 HTTPS 종료, WebSocket·SSE 허용, /metrics 는 운영망에서만 접근
선택 endpoint	내부 Keycloak·AI·SMTP의 DNS·CA·방화벽과 정확한 host 확인

migration 계정이 extension을 만들 수 없다면 DBA가 대상 database에서 먼저 실행합니다.

```
CREATE EXTENSION IF NOT EXISTS pg_trgm;
```

2. 설치

GitHub Release에는 서비스 이미지 `moina-v0.1.31.tar.gz` 하나만 올라가고 SHA256 값은 릴리스 본문에 적힙니다. 파일과 해시를 서로 다른 경로로 반입하세요.

2.1 이미지 반입과 확인

```
sha256sum moina-v0.1.31.tar.gz
gzip -t moina-v0.1.31.tar.gz
gzip -dc moina-v0.1.31.tar.gz | docker image load
docker image inspect moina:v0.1.31 --format '{{.Os}}/{{.Architecture}} {{.Config.User}}'
```

마지막 명령의 결과는 `linux/amd64 nonroot:nonroot` 여야 합니다.

2.2 환경 파일 준비

```
cp .env.example .env
chmod 600 .env
```

.env 에 3장의 네 값을 채웁니다. `MOINA_ENCRYPTION_KEY` 는 다음처럼 만듭니다.

```
openssl rand -base64 32
```

2.3 기동

```
docker compose --env-file .env \  
-f deploy/docker-compose.offline.yml \  
up -d --pull never
```

deploy/docker-compose.offline.yml 의 image: 줄에는 태그가 고정되어 있습니다. 반입한 태그(moina:v0.1.31)와 다르면 그 줄을 반입한 버전으로 맞춘 뒤 기동하세요. pull_policy: never 이므로 이미지가 로컬에 없으면 그 자리에서 실패합니다.

사설 CA가 필요하면 기관의 전체 PEM CA bundle을 mount합니다. 추가 환경변수는 없습니다.

```
install -m 444 /secure/ca-certificates.crt deploy/certs/ca-certificates.crt  
docker compose --env-file .env \  
-f deploy/docker-compose.offline.yml \  
-f deploy/docker-compose.private-ca.yml \  
up -d --pull never
```

사설 루트만 넣으면 기존 공개 TLS 검증이 실패할 수 있습니다. 운영에 필요한 공개 루트와 중간 인증서를 함께 포함하세요.

2.4 기동 확인

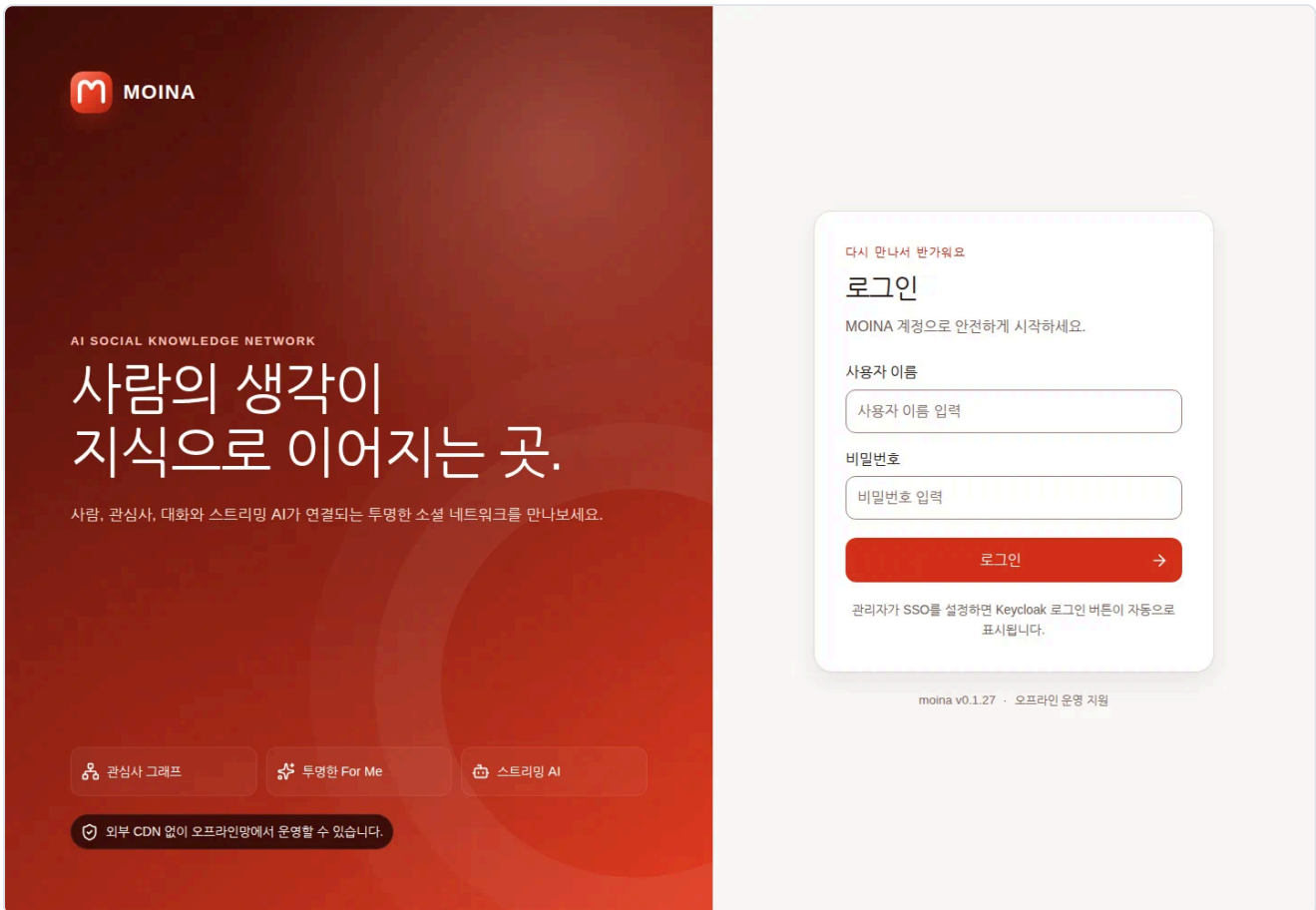
확인	메서드와 경로
프로세스 살아 있음	GET /healthz
요청 받을 준비 완료	GET /readyz
실행 중인 버전	GET /api/v1/version
지표	GET /metrics

```
curl --fail http://127.0.0.1:8080/healthz  
curl --fail http://127.0.0.1:8080/readyz  
curl --fail http://127.0.0.1:8080/api/v1/version  
curl --fail http://127.0.0.1:8080/metrics
```

시작 migration은 대규모 검색 index 생성까지 고려해 최대 30분까지 실행되며, 끝나기 전에는 /readyz 가 성공하지 않습니다. 배포 관리자의 startup 허용 시간도 여기에 맞추세요.

2.5 최초 관리자 계정

1. reverse proxy의 HTTPS 주소로 접속해 로그인 화면 아래의 버전이 방금 올린 버전인지 확인합니다.
2. MOINA_BOOTSTRAP_ADMIN 과 그 비밀번호로 로그인합니다. 이 계정은 `super_admin` 과 `admin` 역할을 함께 가집니다.
3. 설정 → 로그인 보안에서 bootstrap 비밀번호를 즉시 바꿉니다.
4. 운영 관리자와 검토 역할을 따로 만들고 최소 권한만 부여합니다(4장).
5. 감사 로그에 최초 로그인·비밀번호 변경·사용자 생성이 남았는지 확인합니다.



로그인 화면 — 카드 아래에 실행 중인 서비스 버전이 표시된다

bootstrap 값은 최초 계정을 만들기 위한 값입니다. 계정이 이미 만들어진 뒤에 환경변수 비밀번호를 바꿔도 기존 계정은 재설정되지 않습니다.

3. 설정

3.1 환경 변수 — 전부 네 개

서버가 읽는 환경 변수는 정확히 네 개이며, `scripts/check-runtime-contract.sh` 가 이 계약을 CI에서 검사합니다. 나머지는 전부 PostgreSQL에 저장되고 관리 화면에서 바꿉니다.

이름	기본값	필수	설명
MOINA_POSTGRES_DSN	없음	필수	외부 PostgreSQL DSN. 운영에서는 TLS를 검증하는 설정 (<code>sslmode=verify-full</code>)을 씁니다. 예: <code>postgres://moina:비밀값@postgres.internal:5432/moina?sslmode=verify-full</code>
MOINA_BOOTSTRAP_ADMIN	없음	필수	최초 로컬 최고 관리자 아이디. 줄바꿈 없이 1~120자. 예: <code>moina-admin</code>
MOINA_BOOTSTRAP_ADMIN_PASSWORD	없음	필수	최초 관리자 비밀번호. UTF-8 기준 12자 이상, 72바이트 이하. 비밀번호 관리 시스템으로 전달합니다.
MOINA_ENCRYPTION_KEY	없음	필수	저장 비밀번호를 보호하는 32바이트 root key(base64). <code>openssl rand -base64 32</code> 로 만들고 DB backup과 다른 곳에 보관합니다.

MOINA_ENCRYPTION_KEY 를 잃으면 암호화된 OIDC·AI·SMTP 비밀과 기존 session·API key 검증 정보를 복구할 수 없습니다. v0.1.31 은 온라인 root key 교체를 제공하지 않으므로 값을 바꾸지 마세요.

3.2 일반 설정

서비스 관리자 → 일반 설정에서 서비스 공통 정책을 관리합니다. 저장하면 변경 내용과 수행자가 감사 로그에 남습니다 (비밀값 원문은 남지 않습니다). 설정 캐시는 `pg_notify` 로 다른 인스턴스에 곧바로 전파되며, 알림을 놓친 경우에도 30 초 안에 최신 값으로 바꿉니다.

플로우

탐색

검색

필스

알림

포켓

모임

AI

서비스 관리자

관리 대시보드

사용자 관리

콘텐츠 관리

신고·제재

역할·권한

빠른 이동 **Ctrl K**

모인 작성

CA capture-admin
@capture-admin

SERVICE ADMIN

일반 설정

서비스 공통 정책과 API·MCP, 미디어, 선택형 검토·승인 프로세스를 관리합니다.

서비스 기본

저장

서비스 이름

moina

사이트 기본 주소

http://127.0.0.1:18080

외부에서 접근하는 origin이며 OIDC Callback URL 생성에 사용됩니다. 비워두면 현재 요청 주소를 사용합니다.

세션 유지 시간(분)

720

기본 시간대

Asia/Seoul

사용자 가입 허용

기본값은 꺼짐입니다. 끄면 관리자 생성 또는 OIDC 자동 등록만 허용합니다.

☐

API 및 MCP

저장

개인 키를 사용하는 외부 연동 정책입니다.

개인 API 키 인증

사용자가 발급한 최소 권한 키로 REST API에 접근합니다.

☒

Streamable HTTP MCP

개인 키 권한 체계로 /mcp 도구를 제공합니다.

☒

키별 분당 요청 한도

120

서비스 관리자
개인 설정과 분리된 운영 영역

이미지·영상 업로드

저장

JPEG, PNG, GIF, WebP 이미지와 MP4, WebM 영상의 용량·개수·미사용 정리를 관리합니다.

파일당 최대 용량(MiB)

10

1~50MiB

모인당 최대 미디어

4

1~12개

미사용 업로드 정리 시간

24

게시물에 연결되지 않은 파일을 정리할 때까지 1~720시간

Reverse Proxy 신뢰 정책

저장

직접 연결한 Peer가 목록에 있을 때만 Forwarded·X-Forwarded 헤더를 신뢰합니다. 현재 인스턴스에는 즉시, 다른 인스턴스에는 최대 30초 안에 반영됩니다.

신뢰 Proxy IP 또는 CIDR

예: 10.20.0.10

10.30.0.0/24

한 줄에 하나씩 입력하세요. 호스트 이름과 와일드카드는 허용하지 않습니다. 비워 두면 전달 헤더를 모두 무시합니다.

감사 로그에는 소켓 IP, 계산된 실제 Client IP와 Proxy Chain을 각각 기록합니다.

검토·승인 프로세스

정책 저장

설정이 없거나 꺼져 있으면 승인·반려 단계를 완전히 제외합니다.

팀장 검토·승인 사용

지정 작업을 승인 대기로 보내고 승인 메뉴를 표시합니다.

☐

구역	항목	캡처 시점의 값
서비스 기본	서비스 이름	moina
서비스 기본	사이트 기본 주소	사용자가 접근하는 path 없는 origin. OIDC callback URL 생성에 씁니다. 비우면 현재 요청 주소를 사용합니다.
서비스 기본	세션 유지 시간(분)	720
서비스 기본	기본 시간대	Asia/Seoul
서비스 기본	사용자 가입 허용	꺼짐(기본). 고면 관리자 생성 또는 OIDC 자동 등록만 허용합니다.
API 및 MCP	개인 API 키 인증	켜짐
API 및 MCP	Streamable HTTP MCP	켜짐
API 및 MCP	키별 분당 요청 한도	120
이미지·영상 업로드	파일당 최대 용량 (MiB)	10 (1~50)
이미지·영상 업로드	모인당 최대 미디어	4 (1~12)
이미지·영상 업로드	미사용 업로드 정리 시간	24 시간 (1~720)
Reverse Proxy 신뢰 정책	신뢰 Proxy IP 또는 CIDR	비어 있음
검토·승인 프로세스	팀장 검토·승인 사용	꺼짐

몇 가지 고정 규칙은 화면에서 바꿀 수 없습니다.

- 허용 형식은 JPEG·PNG·GIF·WebP 이미지와 MP4·WebM 동영상입니다. HEIC·HEIF는 거절하며, 거절 응답에 아이폰에서 JPEG으로 바꾸는 방법을 함께 안내합니다.
- 사용자별 **미첨부 미디어 100개·512 MiB** quota는 고정 한도입니다. 넘으면 `media_quota_exceeded` 가 표시되고, 기존 업로드를 글·프로필에 연결하거나 정리 시간을 기다려야 합니다.
- 정리 worker는 매시간 500개씩 최대 20 batch, 인스턴스당 시간당 최대 10,000개를 지웁니다.
- 작성 화면은 GET /api/v1/media/config 에서 현재 최대 byte·개수·허용 MIME을 읽습니다. 관리자 전용 정리 시간과 고정 quota는 이 응답에 들어 있지 않습니다.
- 요청 본문 읽기 기한은 미디어 업로드 15분, 그 밖의 요청 30초, header 10초입니다. reverse proxy의 timeout 과 body 크기 제한도 최대 업로드 크기에 맞추세요.
- 로그인·가입과 개인 키 요청 한도는 PostgreSQL에서 계산하므로 여러 인스턴스가 하나의 quota를 공유합니다.

Reverse Proxy 신뢰 정책에는 MOINA에 직접 연결하는 정확한 IP 또는 CIDR만 등록합니다. 호스트 이름과 와일드카드는 허용하지 않고, 비워 두면 전달 header를 모두 무시합니다. 등록된 Peer의 header만 신뢰하며 주소 chain은 오른쪽부터 검증합니다. 감사 로그에는 소켓 IP, 계산된 실제 Client IP와 Proxy Chain이 각각 남습니다.

3.3 보존 기간

일반 설정의 보존 기간(`service.retention`)으로 정리 주기를 정합니다. 기본값은 다음과 같으며 0 은 그 테이블을 정리하지 않는다는 뜻입니다.

대상	기본 보존
감사 기록	무기한(0)
알림	90일
전달을 마친 Outbox event	14일
AI 사용 기록	180일

기동 직후와 매시간, 한 인스턴스가 만료 session과 보존 기간이 지난 행을 테이블당 최대 5,000행씩 20회까지 정리합니다. Dead Letter Outbox event는 보존 기간과 무관하게 남습니다.

3.4 Keycloak OIDC

MOINA

SOCIAL KNOWLEDGE NETWORK

- 플로우
- 탐색
- 검색
- 필스
- 알림
- 포켓
- 모임
- AI

서비스 관리자

- 관리 대시보드
- 사용자 관리
- 콘텐츠 관리
- 신고·제재
- 역할·권한

빠른 이동

Ctrl K

모인 작성

CA

capture-admin

@capture-admin

SERVICE ADMIN

Keycloak OIDC

Issuer URL, Client ID와 Client Secret만으로 SSO를 자동 연결합니다.

OIDC 연결

Issuer Discovery 문서에서 인증·토큰 엔드포인트를 자동 구성합니다.

Keycloak 로그인 사용

로그인 화면에 SSO 버튼을 표시합니다.

Issuer URL

https://keycloak.internal/realms/moina

Client ID

moina

Client Secret

Keycloak에서 Client authentication을 끈 Public client라면 비워두세요.

고급 Redirect URI 직접 지정

http://127.0.0.1:18080/api/v1/auth/oidc/callback

대부분 비워두세요. 비우면 사이트 기본 주소로 Callback URI를 자동 구성합니다.

Scopes

openid profile email

역할 Claim 경로

realm_access.roles

기본 역할

member

역할 매핑 JSON

{ }

예: { "keycloak-admin": ["admin"] }

OIDC 허용 Host

keycloak.internal
sso.internal

줄바꿈 또는 쉼표로 구분합니다. Issuer hostname이 없으면 저장할 때 자동 추가합니다.

사실망 OIDC Host

keycloak.internal

RFC1918-ULA로 해석되는 폐쇄망 DNS 이름만 명시합니다. IP, loopback, link-local과 metadata 주소는 항상 차단됩니다.

Issuer 사실망 연결 허용

먼저 올바른 Issuer URL을 입력하세요.

첫 로그인 사용자 자동 등록

OIDC 프로파일로 사용자를 만들고 기본 역할을 부여합니다.

폐쇄망 HTTP 허용

TLS가 없는 신뢰된 내부망에서만 명시적으로 사용하세요.

실제 로그인 요청 Redirect URI

http://127.0.0.1:18080/api/v1/auth/oidc/callback

현재 접속 주소를 사용합니다.

복사

위 주소를 Keycloak Client의 Valid redirect URIs에 공백 없이 그대로 등록해야 합니다. 연결 테스트는 Keycloak의 실제 Redirect URI 허용 여부까지 확인합니다.

저장 후 연결 테스트

OIDC 설정 저장

서비스 관리자

개인 설정과 분리된 운영 영역

Keycloak OIDC — Issuer·Client 정보, 허용 Host, 실제 Redirect URI 확인과 연결 테스트

1. Keycloak Client에서 Standard flow와 PKCE(s256)를 허용합니다. Confidential client는 Client authentication을 켜고, Public client는 끕니다.

2. **Issuer URL**과 **Client ID**를 입력합니다. Confidential client만 **Client Secret**을 넣고 Public client는 비웁니다. 예전에 Secret을 저장한 Public client는 저장된 Secret 삭제를 겁니다.
3. 화면 아래 실제 로그인 요청 **Redirect URI**에 표시된 주소를 Keycloak의 Valid redirect URIs에 공백 없이 그대로 등록합니다. 고급 **Redirect URI** 직접 지정은 특별한 경우가 아니면 비웁니다.
4. **OIDC 허용 Host**에 issuer와 discovery가 쓰는 정확한 DNS 이름 또는 host:port 를 줄바꿈·쉼표로 구분해 등록합니다. port가 없는 항목은 scheme 기본 port에만 일치합니다.
5. DNS가 RFC1918·ULA 사설 주소를 반환하면 **사설망 OIDC Host**에 그 정확한 DNS 이름을 함께 넣고 **Issuer 사설망 연결 허용**을 겁니다. IP literal은 넣을 수 없고 loopback·link-local·metadata·CGNAT은 항상 차단됩니다.
6. Scopes는 openid profile email 부터 시작하고 기본 역할, 역할 Claim 경로, 역할 매핑 JSON과 첫 로그인 사용자 자동 등록을 정합니다.
7. 저장 후 연결 테스트로 discovery·authorization redirect·token endpoint 인증·DNS/IP·TLS를 모두 확인한 다음 Keycloak 로그인 사용을 겁니다.

Client secret은 저장 후 다시 보여 주지 않고 설정 여부만 표시합니다. 폐쇄망 HTTP는 폐쇄망 HTTP 허용을 명시적으로 켜 등록 host에만 허용됩니다.

SSO 자동 로그인 (autoLogin)

Keycloak에 이미 로그인한 사용자가 MOINA를 열면 로그인 화면 없이 바로 본 화면으로 들어가게 하는 설정입니다. 기본값은 꺼짐이라 켜기 전에는 아무것도 달라지지 않습니다. Keycloak 로그인 사용이 켜져 있어야 동작하며, 관리 API에 서는 PUT /api/v1/admin/oidc 의 autoLogin 필드입니다.

켜면 다음과 같이 동작합니다.

- 세션이 없는 브라우저가 앱 화면(/flow , /moin/{id} 같은 깊은 링크 포함)을 열면 웹 앱이 GET /api/v1/auth/oidc/login?prompt=none&returnTo=... 으로 최상위 이동합니다(숨은 iframe이 아니므로 서드파티 쿠키가 막힌 브라우저에서도 동작합니다). Keycloak은 prompt=none 요청에 화면을 그리지 않고, 세션이 있으면 곧바로 인가 코드를, 없으면 error=login_required 를 돌려줍니다.
- 세션이 있으면 평소 로그인과 같은 절차로 세션을 만들고 원래 열려던 자리로 돌아갑니다. returnTo 는 / 로 시작하고 // 로 시작하지 않는 앱 내부 경로만 받습니다.
- 세션이 없으면 callback이 /login?sso=none 으로 보내 로그인 화면을 보여 줍니다. 이것은 실패가 아니라 평범한 답이므로 오류로 기록하지 않습니다.
- 사용자가 직접 로그아웃하면 그 탭에서는 다시 조용히 로그인시키지 않습니다. 다시 로그인해 세션이 생기면 풀립니다.
- 시도는 브라우저 탭 세션에 한 번만 합니다(sessionStorage). 새 탭에서는 다시 시도하고, 거절당한 뒤 새로그침 하면 시도하지 않습니다. 사생활 보호 모드처럼 저장소를 읽지 못하면 이미 시도한 것으로 쳐서 리다이렉트가 반복 되지 않게 합니다.
- 로그인 화면(/login)과 API·MCP·상태 점검 경로에서는 시도하지 않습니다.
- 설정이 꺼져 있으면 주소에 ?prompt=none 을 붙여 불러도 서버가 평범한 로그인으로 바꿉니다. 흐름을 바꿀 수 있는 자리는 이 설정 하나뿐입니다.

Keycloak 쪽 준비는 평소 로그인과 같습니다. Valid redirect URIs에 callback 주소가 등록돼 있고 연결 테스트가 통과 하면 그대로 켤 수 있습니다. 성공한 자동 로그인은 감사 로그 auth.oidc.login 에 silent: true 로 남습니다.

오류 코드는 다음과 같이 읽습니다.

코드	뜻
<code>oidc_client_auth_failed</code>	Keycloak의 Client authentication 설정과 저장된 Secret/Public client 설정이 어긋남
<code>oidc_code_rejected</code>	만료·재사용된 코드, PKCE·Redirect URI 불일치 또는 서버 시간 문제

MCP SSO (OAuth) — 키 없이 Keycloak 토큰으로 /mcp 연결

MCP 인가 규격(2025-06-18 이후)은 OAuth 2.1입니다. 이 설정을 켜면 MCP 클라이언트(Claude, Cursor 등)에 MCP 주소 하나만 주면 클라이언트가 스스로 Keycloak 로그인 화면을 띄우고 액세스 토큰을 받아 /mcp 에 붙입니다. 개인 키(`mk_`)는 그대로 남고, 같은 `Authorization: Bearer` 헤더에서 접두사가 `mk_` 면 키, JWT 모양이면 Keycloak 토큰으로 가립니다. 기본값은 꺼짐이고, MOINA는 리소스 서버일 뿐이라 `/authorize` · `/token` · 클라이언트 등록을 만들지 않습니다 — 로그인만 Keycloak이 합니다.

같은 Keycloak OIDC 화면 아래 MCP SSO (OAuth) 카드에서 설정합니다(관리 API는 `PUT /api/v1/admin/oidc` 의 `mcp0auth` 객체).

표준 이름	화면 항목 / 필드	기본값	뜻
<code>mcp.oauth.enabled</code>	Keycloak 토큰으로 MCP 연결 / <code>mcp0auth.enabled</code>	꺼짐	켜려면 Issuer URL과 Client ID가 있어야 하며 저장 시 검증합니다. 웹 로그인 스위치와 별개입니다
<code>mcp.oauth.resource</code>	리소스 식별자 / <code>mcp0auth.resource</code>	빈 값	토큰의 <code>aud</code> 가 가리켜야 하는 공개 MCP 주소. 비우면 일반 설정의 사이트 기본 주소 + <code>/mcp</code> , 둘 다 없으면 요청 주소 (마지막 수단)
<code>mcp.oauth.audience</code>	허용 대상(<code>aud/azp</code>) / <code>mcp0auth.audience</code>	빈 값	공백 구분. 토큰의 <code>aud</code> 또는 <code>azp</code> 가 이 목록에 있으면 통과. 보통 MCP 클라이언트의 Client ID
<code>mcp.oauth.scopes</code>	SSO 주체 권한 범위 / <code>mcp0auth.scopes</code>	<code>posts:read</code> <code>mcp:use</code>	토큰으로 들어온 사용자에게 주는 권한 상한. 역할 권한과 교집합만 적용됩니다. <code>mcp:use</code> 가 빠지면 MCP를 열 수 없습니다
(재사용) <code>oidc.issuer_url</code> · <code>oidc.client_id</code>	Issuer URL · Client ID	—	새로 만들지 않습니다. 발급자 검사와 discovery·JWKS 조회에 씁니다

켜져 있어도 issuer·리소스 식별자·MCP(API 접근 설정의 MCP 스위치) 중 하나가 없으면 조용히 꺼진 것처럼 동작하고 카드와 서버 로그에 이유를 남깁니다. 리소스 식별자는 프록시 뒤 주소가 아니라 클라이언트가 실제로 접속하는 공개 HTTPS 주소여야 하므로 **일반 설정의 사이트 기본 주소를 먼저 채우세요.**

서버가 토큰을 받아들이는 조건은 다음 전부입니다.

- Keycloak JWKS로 서명이 맞고 알고리즘이 RS/ES/PS 계열(HS·none 거부), `iss` 가 Issuer URL과 같고, `exp` · `nbf` 가 유효하다.
- `typ` 이 ID 가 아니고(ID 토큰은 로그인 증거이지 API 자격이 아닙니다), `cnf` 가 없고, `sub` 가 있다.
- **대상:** `aud` 에 리소스 식별자가 있거나, `aud` 또는 `azp` 가 허용 대상(또는 웹 로그인 Client ID)에 있다. 실제 Keycloak 26은 `aud` 에 `account` 만 싣고 클라이언트 ID를 `azp` 에 담으므로 매퍼 없이 쓰려면 허용 대상에 MCP 클라이언트 ID를 적으면 됩니다.
- `sub` 로 이미 웹 로그인으로 연결된 활성 계정이 있다. 계정을 만들거나 정지된 계정을 되살리거나 토큰의 role로 권한을 올리는 일은 없습니다. 권한은 `mcp.oauth.scopes` ∩ 역할 권한이고, 요청 한도는 키와 같은 분당 값을 사용자 별로 씁니다.

토큰은 `/mcp` · `/api/v1/mcp` 에서만 받습니다. REST·WebSocket·관리 API는 지금처럼 키와 세션만 받으며, 유효한 토큰을 REST에 보내도 평범한 401입니다. 토큰을 저장하거나 세션으로 바꾸지 않고 요청마다 검사하므로 Keycloak에서 로그아웃해도 이미 발급된 토큰은 만료까지 삽니다 — 액세스 토큰 수명을 짧게(5분 안팎) 두세요.

Keycloak 쪽 할 일

1. MCP 클라이언트용 **Public client**를 웹 로그인 클라이언트와 따로 만듭니다. Standard flow 컴, PKCE S256 , Direct access grants·Implicit·Service accounts 끄.
2. Valid redirect URIs에 쓰는 MCP 클라이언트의 콜백을 정확히 적습니다(Claude는 `https://claude.ai/api/mcp/auth_callback` , 로컬 클라이언트는 `http://127.0.0.1:*/callback` 류). * 하나로 다 여는 것은 금지입니다.
3. 정식 경로: 그 클라이언트(또는 전용 client scope)에 **Audience 매퍼** — Included Custom Audience = 리소스 식별자(`https://<공개 주소>/mcp`), Add to access token 컴, Add to ID token 끄. 호환 경로: 매퍼 없이 MOINA의 허용 대상에 그 클라이언트 ID를 적습니다.
4. 액세스 토큰 수명을 짧게 둡니다.

확인 방법

```
# 1. 메타데이터 — 인증 없이 맨 JSON. 꺼져 있으면 404 mcp_oauth_disabled
curl --silent https://moina.example/.well-known/oauth-protected-resource/mcp
# {"resource":"https://moina.example/mcp","authorization_servers":["https://keycloak.internal/realms/moina"]
# "bearer_methods_supported":["header"],"scopes_supported":["posts:read","mcp:use"],"resource_name":"moina

# 2. 401이 길을 가리키는지 — MCP 경로에서만 WWW-Authenticate가 붙습니다
curl --silent --include -X POST https://moina.example/mcp -H 'Content-Type: application/json' \
  --data '{"jsonrpc":"2.0","id":1,"method":"tools/list"}' | grep -i www-authenticate
# WWW-Authenticate: Bearer realm="MOINA", resource_metadata="https://moina.example/.well-known/oauth-protected-resource/mcp"

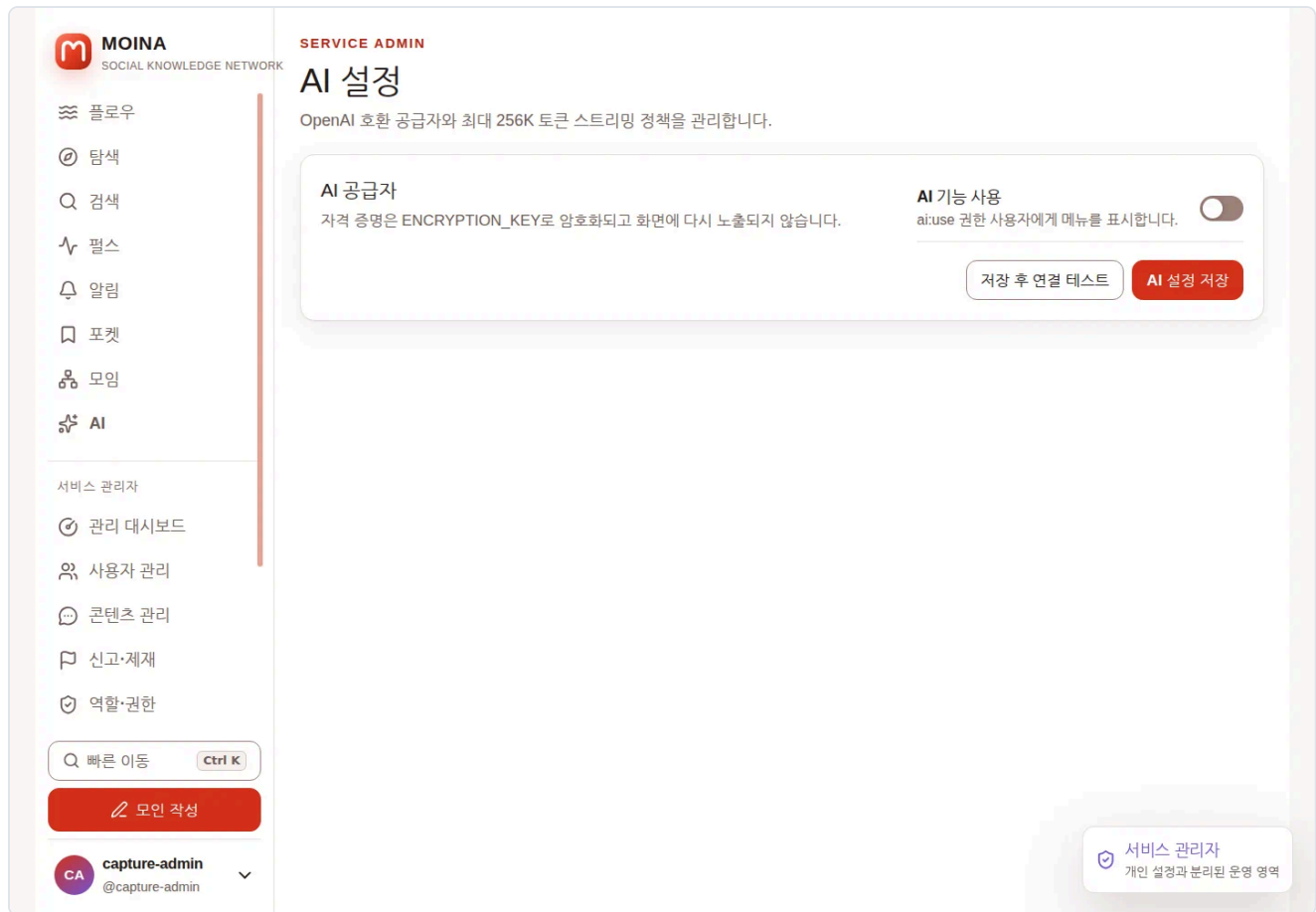
# 3. 토큰으로 tools/list — 거부되면 본문 message가 이유를 말합니다
curl --silent -X POST https://moina.example/mcp -H "Authorization: Bearer $ACCESS_TOKEN" \
  -H 'Content-Type: application/json' --data '{"jsonrpc":"2.0","id":1,"method":"tools/list"}'
```

거부 메시지별 조치 (401, code: invalid_token, 헤더에 error="invalid_token" ; 원인은 서버 로그 MCP SSO 토큰 거부 의 reason · error 에 남습니다)

메시지	뜻	조치
이 서버를 위해 발급된 것이 아닙니다(aud=..., azp=...)	다른 애플 토큰이거나 매퍼·허용 대상이 없음	메시지가 말하는 azp 값을 허용 대상에 적거나, Keycloak 클라이언트에 Audience 매퍼로 리소스 식별자를 넣습니다
유효하지 않습니다(서명·발급자·만료·nbf·알고리즘)	JWKS로 서명이 안 맞거나, iss 가 다르거나, 만료	Issuer URL이 realm과 정확히 같은지, 서버 시간이 맞는지, 클라이언트가 이 realm에서 받은 토큰인지 확인합니다
ID 토큰은 로그인 증거이지 API 자격이 아닙니다	클라이언트가 id_token 을 보냄	클라이언트가 access_token 을 쓰도록 합니다
소지자 증명(cnf)이 묶인 토큰	DPoP·mTLS 바인딩 토큰	그 클라이언트에는 바인딩 없는 토큰을 발급합니다
등록되지 않았거나 비활성입니다. 먼저 웹으로 한 번 로그인하세요	sub 에 연결된 활성 계정이 없음	그 사용자가 웹에서 SSO로 한 번 로그인하게 하거나(연결이 생깁니다) 계정을 활성화합니다
Keycloak 발급자 정보를 읽지 못해...	discovery 실패	OIDC 허용 Host·사설망 설정과 저장 후 연결 테스트를 확인합니다
403 forbidden	토큰은 통과했지만 범위에 mcp:use 가 없음	SSO 주체 권한 범위에 mcp:use 를 넣습니다

긴급 접근을 위해 로컬 최고 관리자 계정을 최소 한 개 유지하고, 강한 비밀번호와 접근 통제를 적용하세요.

3.5 AI 스트리밍



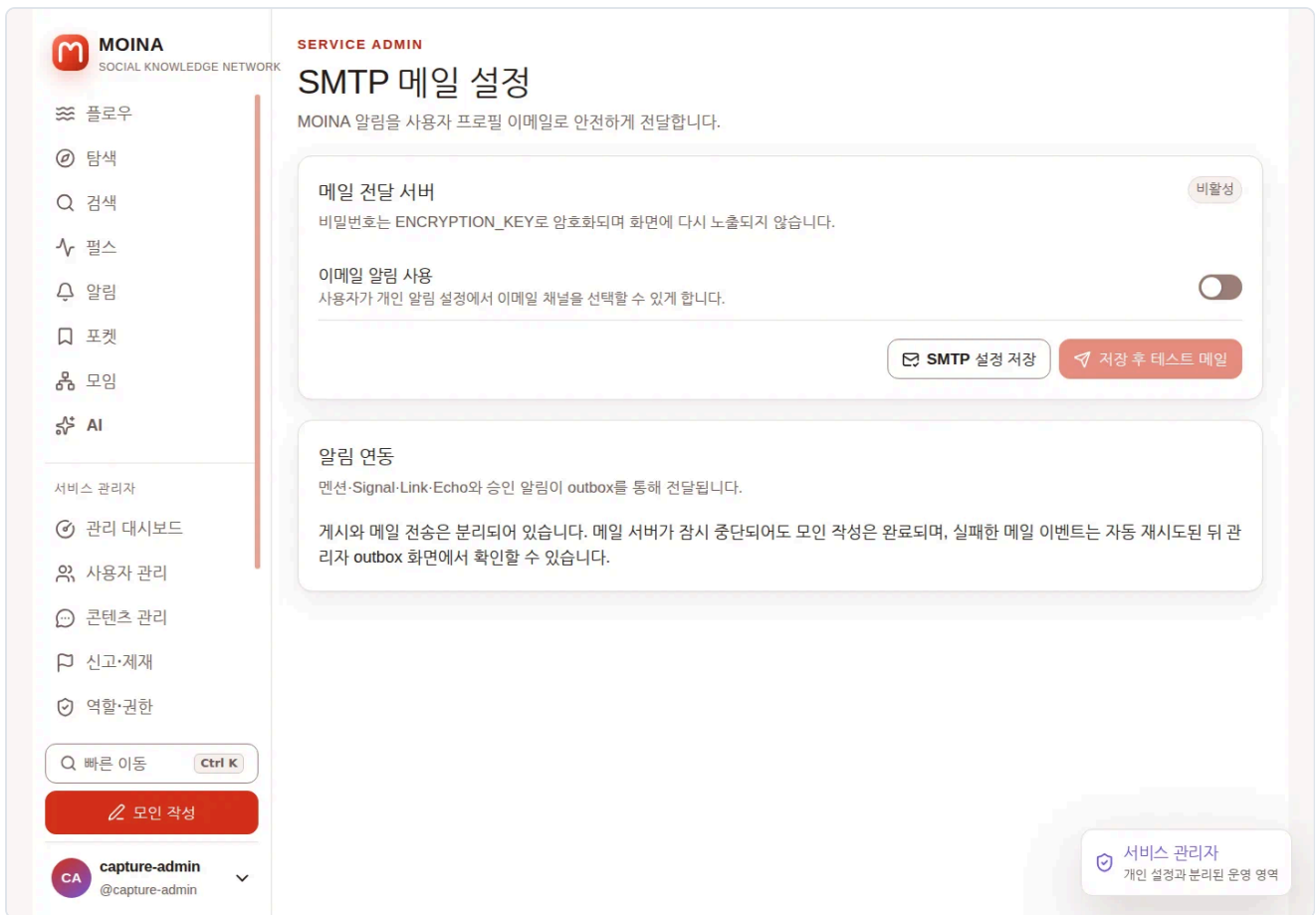
AI 설정 — OpenAI 호환 공급자 연결과 AI 기능 사용 스위치

내부 OpenAI 호환 endpoint의 base URL, API key, model, API style, timeout, token 정책과 허용 호스트를 저장합니다. API key는 MOINA_ENCRYPTION_KEY 로 암호화되고 조회 응답에 반환되지 않습니다.

- output token 허용 범위는 1~262,144이지만 실제 model 상한 이하로 설정합니다.
- 허용 호스트에는 정확한 DNS/IP 또는 host:port 만 등록합니다. RFC1918·ULA로 해석되는 내부 endpoint는 전체 허용과 사설망 허용 목록에 함께 넣습니다. 차단되는 주소 범주는 OIDC와 같습니다.
- 요청마다 DNS를 다시 해석해 검증한 IP로 연결하고 모든 redirect를 다시 검사합니다.
- 저장 후 연결 테스트는 저장된 설정으로 /models 응답을 확인합니다.
- streaming(SSE)을 reverse proxy가 buffering하지 않도록 하세요.

AI 기능을 켜면 ai:use 권한이 있는 사용자에게만 메뉴가 보입니다. host allowlist와 별개로 outbound 방화벽에서도 같은 목적지만 허용하세요.

3.6 SMTP 메일

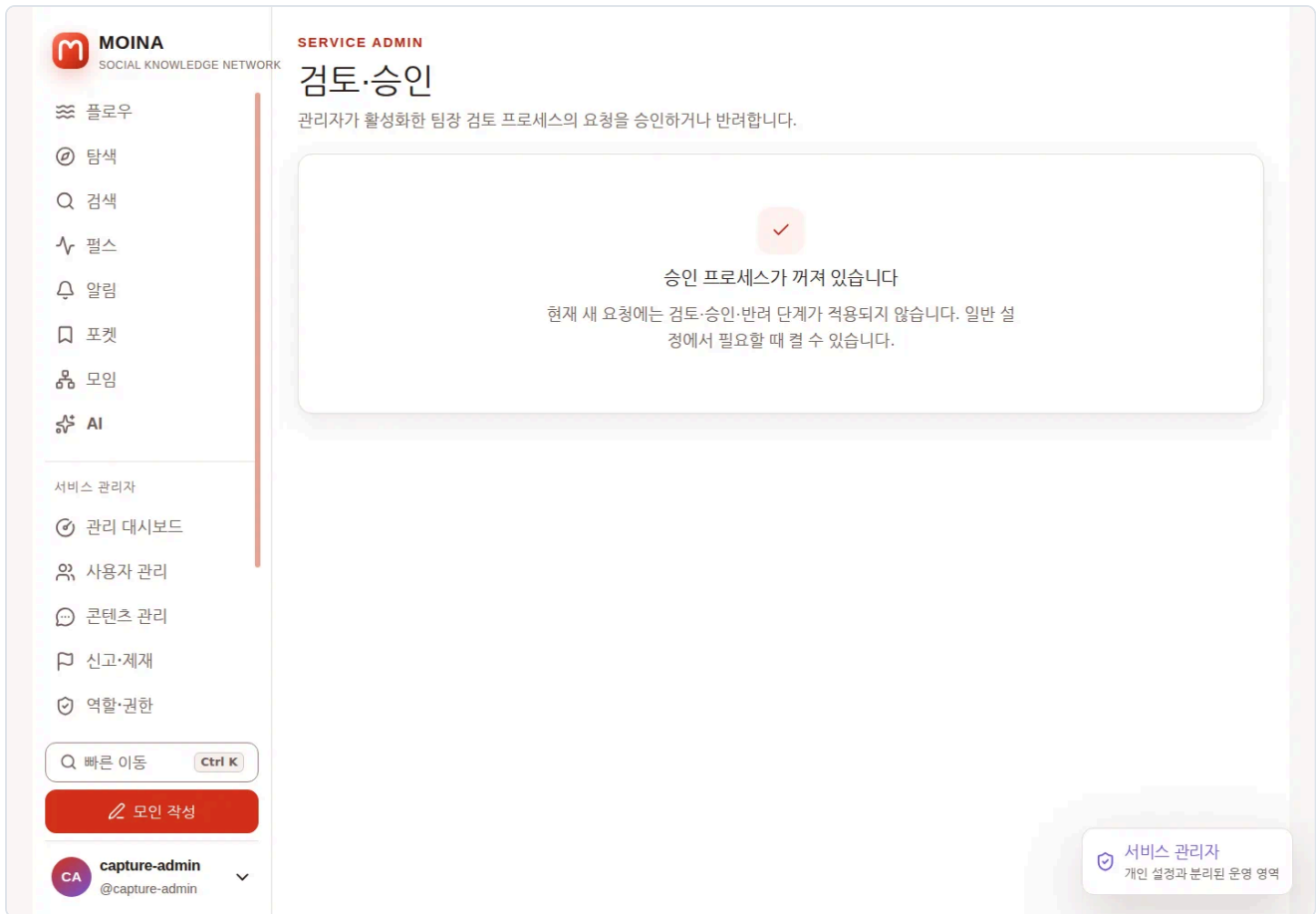


SMTP 메일 설정 — 메일 전달 서버, 이메일 알림 사용, 저장 후 테스트 메일

1. 서버 DNS 이름과 port를 나눠 입력합니다.
2. STARTTLS를 기본으로 쓰고 공급자가 요구할 때만 TLS (SMTPS)를 고릅니다. 암호화 없음은 폐쇄망 무인증 relay에서만 선택합니다.
3. 사용자 이름·password와 보내는 이메일·이름을 입력합니다. Password는 암호화되어 조회 응답과 감사 로그에 원문이 나오지 않습니다.
4. DNS가 사설 주소를 반환하는 내부 서버만 사설망 SMTP 허용을 켭니다. 입력한 정확한 host:port 하나만 열립니다.
5. 저장 후 테스트 메일로 현재 관리자 프로필 이메일에 실제 메일이 도착하는지 확인합니다.
6. 이메일 알림 사용을 켜면 사용자가 개인 알림 설정에서 이메일 채널을 고를 수 있습니다.

메일은 별도 notification.email Outbox event로 보내므로 SMTP 장애가 Moin 게시를 실패시키지 않습니다. 실패는 지수 backoff 뒤 Dead Letter에 남고, 원인을 해결한 다음 감사 로그의 실패 이벤트 복구에서 재처리합니다. 사설 CA를 쓰는 SMTP TLS는 기관 CA bundle에 root와 intermediate를 모두 포함해야 합니다.

3.7 선택형 검토·승인 정책



검토·승인 — 승인 프로세스가 꺼져 있을 때의 안내

승인 정책이 꺼져 있으면 제출·검토·승인·반려 단계와 승인 메뉴가 화면에서 완전히 빠집니다. 켤 때는 일반 설정의 **검토·승인 프로세스**에서 지정 Action만 고릅니다.

- Action 패턴은 전체 *, 정확한 dot Action, 마지막 segment만 wildcard인 post.* 형태만 허용합니다. post*, post., post:*, *.publish, post..publish 는 거절됩니다.
- 모든 approver 역할에 최종 유효 approvals:review, approvals:* 또는 * 권한이 있어야 하며, 하나라도 어긋나면 저장에 거부됩니다.
- 요청자의 자기 승인·반려는 금지되고, 승인 대기 중인 Moin은 수정할 수 없습니다.
- 승인 대상과 Pending 요청 접근 권한은 요청마다 다시 검사하므로 권한을 회수한 사용자는 즉시 검토할 수 없습니다.
- 승인·반려 event는 수행자·시각·대상·결과·검토 comment와 함께 감사 로그에 남습니다.

3.8 방문 추적(애널리틱스)

서비스 관리자 → 일반 설정의 맨 아래 방문 추적 카드에서 방문 통계 스니펫을 화면에 붙입니다. 기본값은 꺼짐이며, 새로 설치한 곳은 이 카드를 켜기 전까지 아무것도 달라지지 않습니다. 환경 변수는 없고 설정은 PostgreSQL에 저장되어 재배포 없이 바꿀 수 있습니다.

항목	뜻
방문 추적 사용	꺼짐이 기본입니다. 켜야 스니펫이 붙습니다
Provider	Momento (사내 수집기) · Google Analytics 4 · Google Tag Manager · Matomo · 직접 붙여 넣기
Momento 수집기 주소 · 사이트 ID	수집기 URL(query·fragment 없음)과 사이트 id
같은 오리진 프록시 사용	서버가 /momento/* 를 수집기로 넘기고 스니펫에 data-endpoint="/momento" 를 줍니다. 권장·기본값
사설망 수집기 허용	수집기 DNS 이름이 RFC1918·ULA 주소로 해석될 때만 컵니다. IP 직접 입력·loopback은 거절
측정 ID · 컨테이너 ID	GA4 · GTM의 id
Matomo 주소 · 사이트 ID	Matomo URL과 사이트 id
추적 코드	추적 도구가 준 <script> 스니펫. 8KB를 넘으면 저장되지 않습니다
추가 허용 출처	스니펫에서 자동으로 읽지 못한 https://host[:port] 출처, 한 줄에 하나
관리 화면에도 붙이기	기본은 아니오. /admin 으로 시작하는 화면을 새로 열 때는 스니펫을 넣지 않습니다
삽입 위치	head 끝 또는 body 끝

Momento를 먼저 고릅니다. Momento는 사내 자체 호스팅 수집기라 방문 데이터가 밖으로 나가지 않는 유일한 선택 지입니다. 프록시를 켜 기본 구성에서는 브라우저가 /momento/tracker.js 를 MOINA 자기 오리진에서 받고 이벤트도 /momento 로 보내므로 정책에 외부 출처가 아예 등장하지 않습니다. 프록시는 OIDC·AI·SMTP와 같은 exact-authority 아웃바운드 정책으로 수집기 주소 하나에만 연결하고, 세션 cookie·Authorization 헤더는 수집기로 넘기지 않으며 수집기의 Set-Cookie 도 브라우저로 돌려주지 않습니다. 수집기 주소를 http:// 로 적으면 그 주소에만 평문 HTTP를 허용합니다.

순서는 이렇습니다.

1. 방문 추적 사용을 켜고 provider를 고릅니다(기본 선택은 Momento).
2. 수집기 주소와 사이트 ID를 넣고 방문 추적 저장을 누릅니다.
3. 사용자 화면(예: 플로우)을 새로 엽니다. 스니펫은 문서를 새로 받을 때 들어가므로 이미 열려 있던 탭은 새로 고쳐야 합니다.
4. 수집기 화면에 방문이 들어오는지 확인합니다. 들어오지 않으면 아래 정책이 차단한 출처를 봅니다.

Content-Security-Policy와 nonce

MOINA의 화면 정책은 script-src 'self' 로 잠겨 있어 스니펫을 그냥 붙이면 브라우저가 조용히 막습니다. 그래서 추적을 켜면 서버가 요청마다 nonce를 만들어 스니펫의 모든 <script> 에 nonce="..." 를 붙이고, 같은 값을 그 응답의 script-src 'nonce-...' 에 넣습니다. 정책을 'unsafe-inline' 으로 풀지는 않습니다 — 한 번 풀면 그 앱의 모든 인라

인 스크립트가 함께 허용되고 추적을 끈 뒤에도 느슨한 채 남기 때문입니다. 추적을 끄면 정책은 원래대로 좁아집니다.

스니펫이 가리키는 출처는 서버가 읽어 `script-src · connect-src · img-src` 에 더합니다. Momento 직접 연결 · Matomo는 입력한 주소의 출처, GA4·GTM은 Google 수집 출처, 직접 붙여 넣은 코드는 본문에 적힌 `http(s)://...` 주소의 출처입니다. 그래도 막히는 것이 있으면 추적이 켜진 동안에만 정책에 들어가는 `report-uri` 로 브라우저가 서버에 신고하고, 카드 아래 **정책이 차단한 출처** 표에 출처·지시어·횟수가 보입니다. **허용**을 누르면 그 출처가 **추가 허용 출처**에 들어가 저장까지 끝나고, **기록 비우기**로 지운 뒤 화면을 다시 열어 남는 차단이 있는지 확인합니다. 이 기록은 인스턴스 메모리에만 있으며(서로 다른 출처 최대 100개) 재시작하면 비워집니다.

`/api/* · /mcp · /healthz · /readyz · /metrics · /momento/*` 같은 비화면 응답에는 스니펫이 붙지 않고 정책도 `default-src 'none'` 으로 더 좁습니다. 로그인 화면에도 스니펫이 붙으므로 개인 식별 값을 보내는 스니펫은 쓰지 마세요.

API는 `GET · PUT /api/v1/admin/analytics`, `GET · DELETE /api/v1/admin/analytics/violations`, `POST /api/v1/admin/analytics/violations/allow ( settings:manage )`이며, 브라우저 신고는 `POST /api/v1/analytics/csp-report` (무인증, 항상 204)로 들어옵니다.

4. 계정과 권한

4.1 사용자 관리

MOINA

SOCIAL KNOWLEDGE NETWORK

- 플로우
- 탐색
- 검색
- 펄스
- 알림
- 포켓
- 모임
- AI

서비스 관리자

- 관리 대시보드
- 사용자 관리**
- 콘텐츠 관리
- 신고·제재
- 역할·권한

빠른 이동

Ctrl K

모인 작성

CA

capture-admin

@capture-admin

SERVICE ADMIN

사용자 추가

사용자 관리

로컬·OIDC 사용자 상태와 역할을 관리합니다.

이름, 사용자 이름, 이메일 검색

새로고침

사용자	인증	역할	상태	등록일	관리
capture-admin @capture-admin	로컬	super_admin	활성	2026년 9월 11일	비활성화

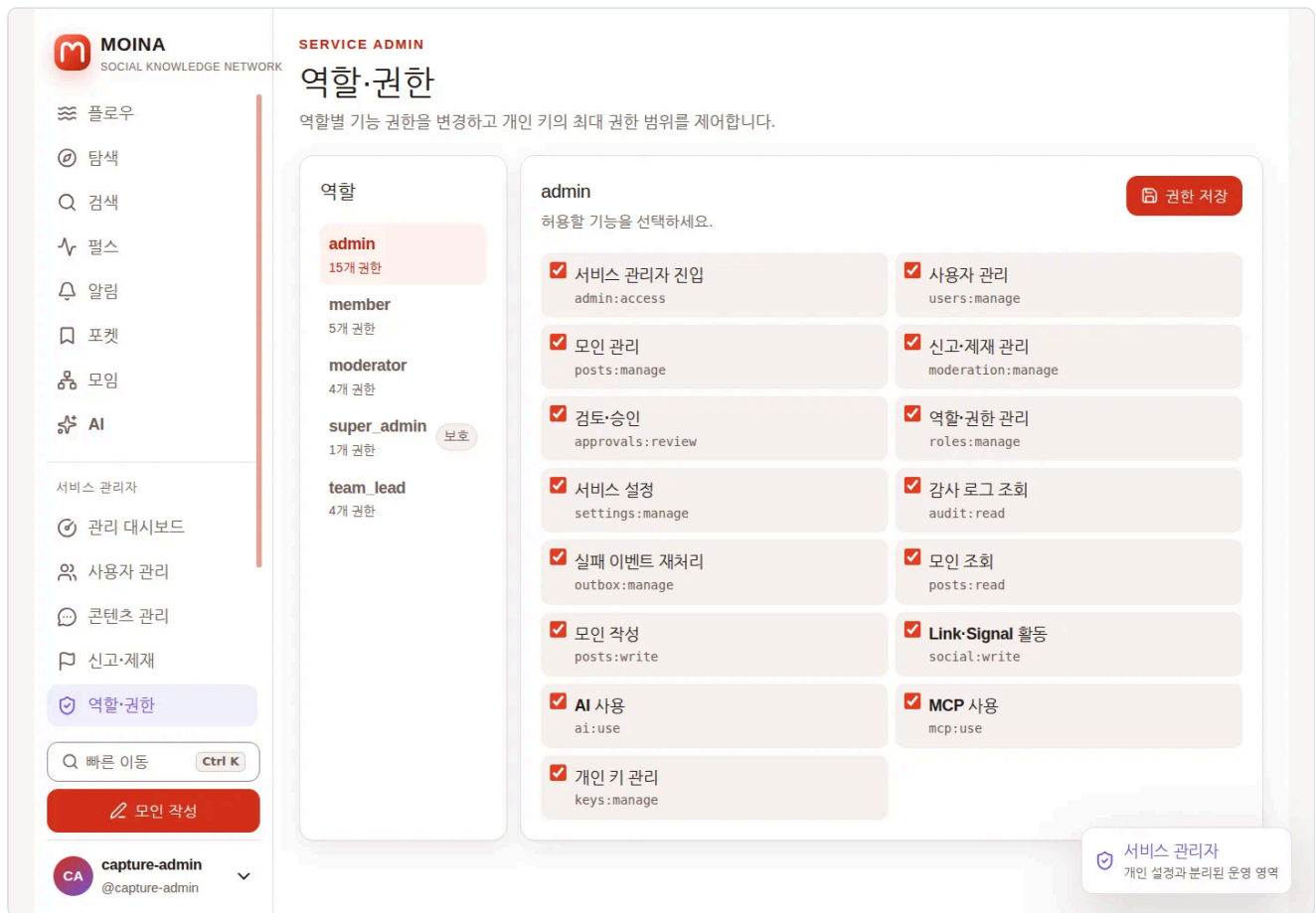
서비스 관리자

개인 설정과 분리된 운영 영역

사용자 관리 — 로컬·OIDC 사용자 목록과 역할 변경, 비활성화

목록에서 인증 방식(로컬·OIDC), 역할, 상태와 등록일을 확인하고 역할을 바꾸거나 계정을 비활성화합니다. 최고 관리자 계정은 최고 관리자만 바꿀 수 있고(`super_admin_protected`), 마지막 최고 관리자는 변경할 수 없습니다(`last_super_admin`).

4.2 역할과 권한



역할·권한 — 역할별 기능 권한 선택과 권한 저장

기본 역할과 권한은 다음과 같습니다. 역할 이름과 권한 묶음은 이 화면에서 바꿀 수 있고, 서버는 화면 숨김이 아니라 모든 API 요청에서 권한을 다시 검사합니다.

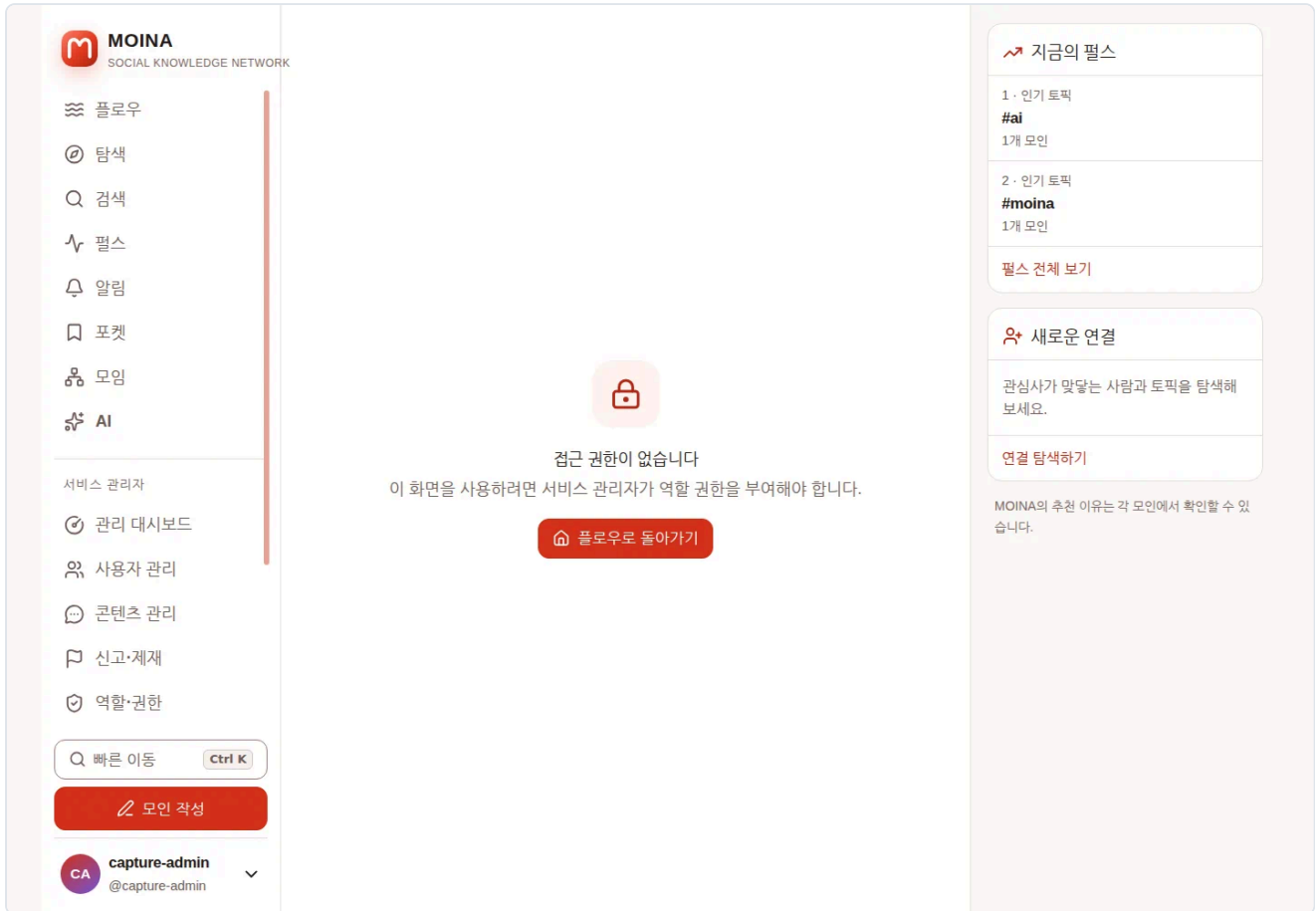
역할	설명	기본 권한
super_admin	전체 서비스 관리	* (보호되어 변경·삭제 불가)
admin	서비스 운영 관리	admin:access , users:manage , posts:manage , moderation:manage , approvals:review , roles:manage , settings:manage , audit:read , outbox:manage , keys:manage , posts:read , posts:write , social:write , ai:use , mcp:use
team_lead	검토 및 승인	approvals:review , posts:read , ai:use , mcp:use
moderator	신고 및 콘텐츠 운영	moderation:manage , posts:manage , posts:read , ai:use
member	일반 사용자	posts:read , posts:write , social:write , ai:use , mcp:use

권한이 뜻하는 것은 다음과 같습니다.

권한	할 수 있는 일
admin:access	서비스 관리자 영역 진입
users:manage	사용자 생성·역할 변경·비활성화·비밀번호 초기화
posts:manage	콘텐츠 관리에서 Moin 조회·수정·삭제
moderation:manage	신고 검토와 제재 처리
approvals:review	검토·승인 요청 승인·반려
roles:manage	역할과 권한 편집
settings:manage	일반·OIDC·AI·SMTP·승인 설정 변경
audit:read	감사 로그와 실패 이벤트 조회
outbox:manage	실패 이벤트 재처리
keys:manage	다른 사용자 API·MCP 키 조회·회수
posts:read / posts:write	Moin 읽기 / 쓰기
social:write	Link·Signal·Pocket·신고 등 사회적 활동
ai:use / mcp:use	AI 메뉴 사용 / MCP endpoint 사용

조사 역할과 복구 역할을 분리하세요. 실패 이벤트 조하는 `audit:read` , 상태를 바꾸는 재처리 는 `outbox:manage` 로 나뉘어 있습니다.

권한이 없는 화면을 열면 사용자에게는 다음 화면이 보입니다. 사용자가 이 화면을 신고해 오면 역할과 유효 권한을 확인해 주세요.



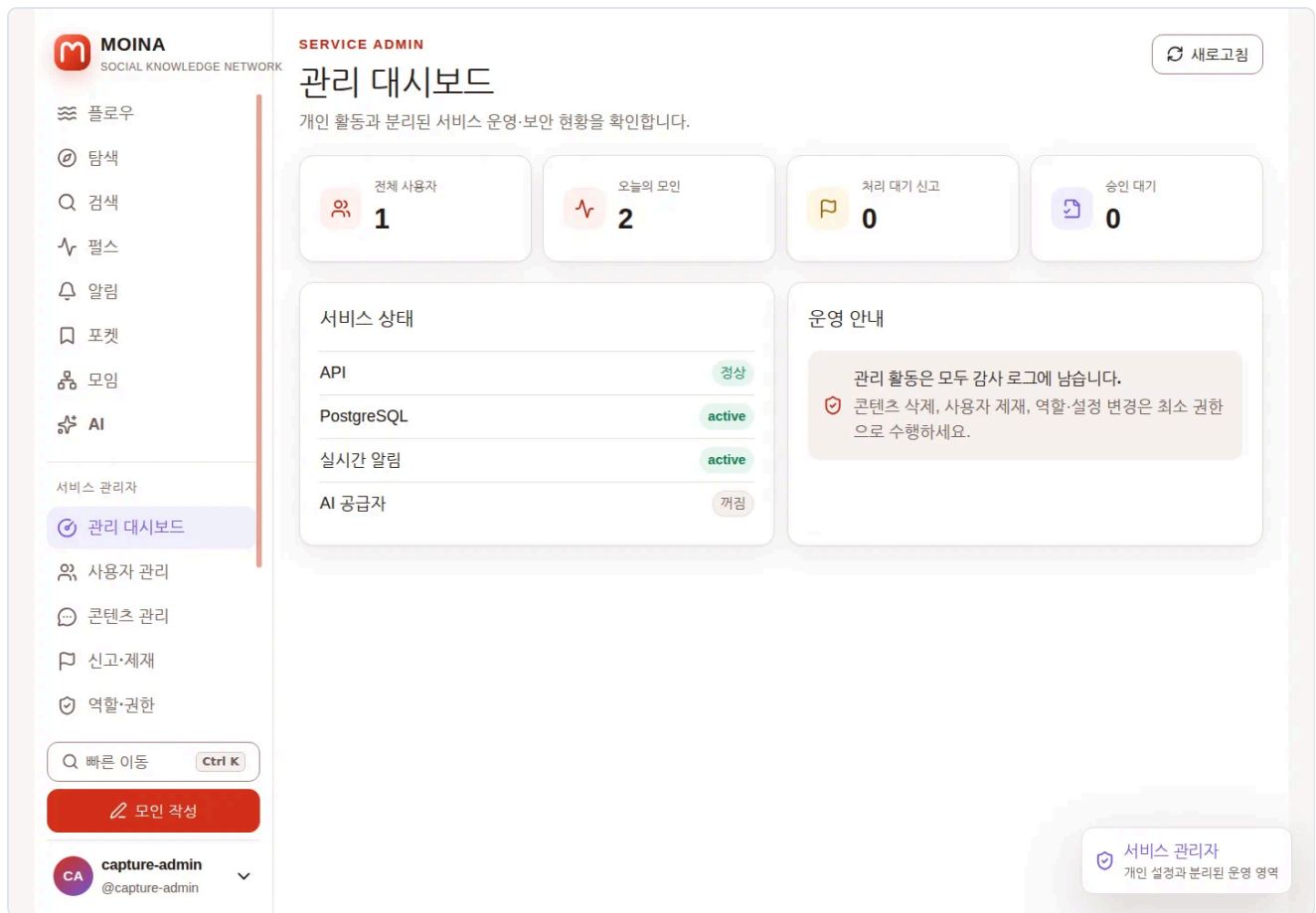
접근 권한이 없습니다 — 권한 없는 화면을 열었을 때 사용자에게 보이는 화면

4.3 개인 API·MCP 키

키는 소유자별로 hash만 저장하고 원문은 생성·회전 직후 한 번만 표시됩니다. 만료와 최근 사용 시각이 함께 기록되므로 장기 미사용 키와 만료 없는 키를 주기적으로 검토하세요. MCP도 같은 권한 체계와 요청 한도를 씁니다. 역할을 바꾸면 활성 session과 키의 유효 권한에 즉시 반영됩니다. Keycloak을 쓰는 곳은 3.4절의 ****MCP SSO (OAuth)****를 켜면 사용자가 키 없이 SSO 토큰으로 `/mcp` 에 붙을 수 있습니다 — 키 체계는 그대로 남습니다.

5. 운영

5.1 관리 대시보드



관리 대시보드 — 사용자·모인·신고·승인 현황과 API·PostgreSQL·실시간 알림·AI 상태

전체 사용자, 오늘의 모인, 처리 대기 신고, 승인 대기 수와 함께 API·PostgreSQL·실시간 알림·AI 공급자의 상태를 한 화면에서 봅니다. 관리 활동은 모두 감사 로그에 남습니다.

5.2 콘텐츠와 신고


MOINA
 SOCIAL KNOWLEDGE NETWORK

플로우
 탐색
 검색
 펄스
 알림
 포켓
 모임
 AI

서비스 관리자
 관리 대시보드
 사용자 관리
콘텐츠 관리
 신고·제재
 역할·권한

빠른 이동 Ctrl K

모인 작성


capture-admin
 @capture-admin

SERVICE ADMIN

콘텐츠 관리

모인과 커뮤니티 콘텐츠를 검색하고 운영 정책에 따라 조치합니다.

새로고침

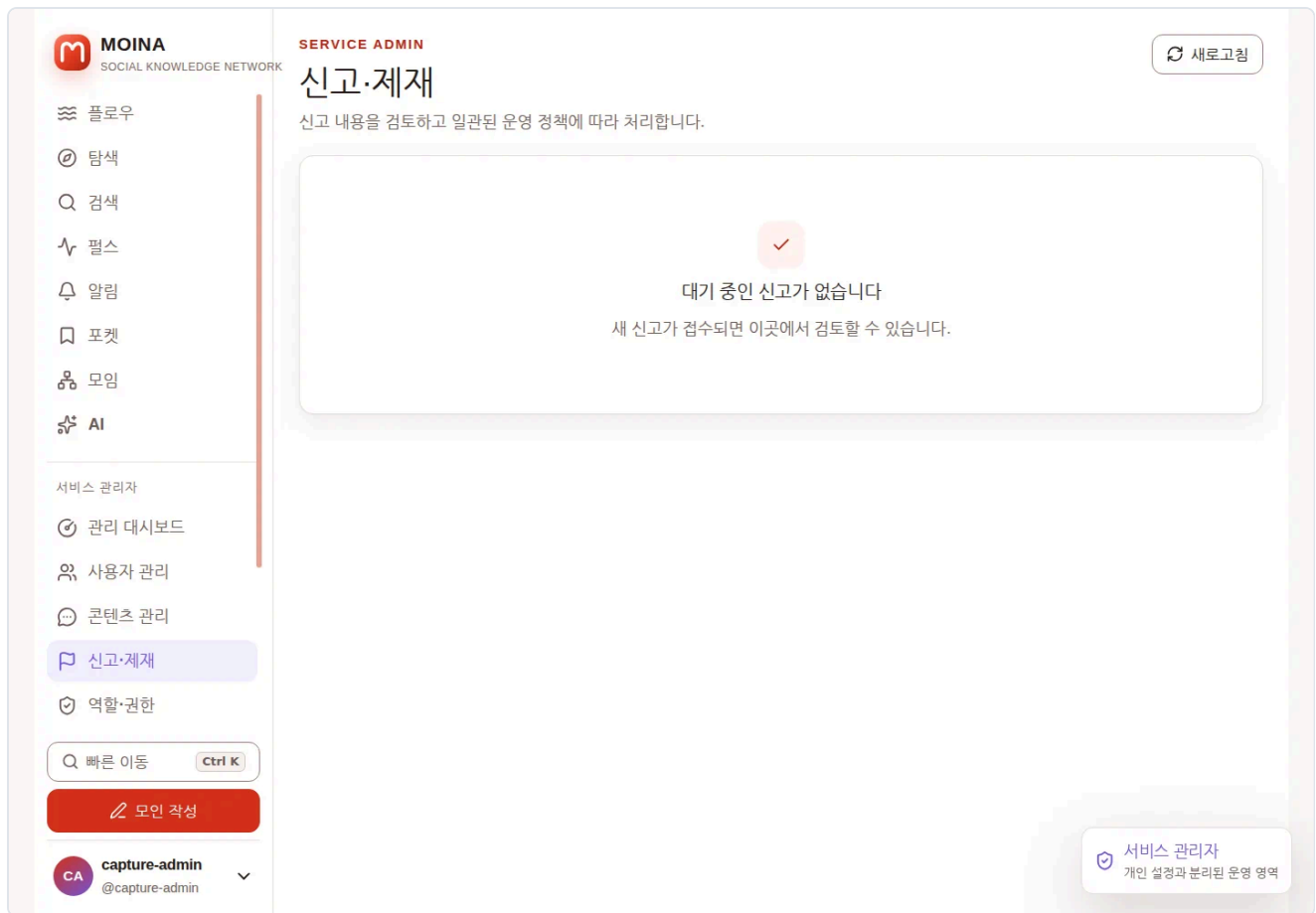
내용	작성자	신고	상태	작성일	조치
MOINA 연구소에서 이어지는 첫 대화입니다. ... moin_EoT3iBu0rKQZAgAH5MwkkX24	@capture-admin	0건	published	2026년 9월 11일 오전 05:54	삭제
사람과 생각이 지식으로 모이는 MOINA를 시... moin_5P2Uc1VGIMvoGEa0yOZ9yxw-	@capture-admin	0건	published	2026년 9월 11일 오전 05:54	삭제

서비스 관리자

개인 설정과 분리된 운영 영역

콘텐츠 관리 — 내용·작성자로 검색하고 상태를 확인한 뒤 삭제한다

콘텐츠 관리에서 내용이나 작성자로 Moin을 찾아 상태(published 등)와 신고 건수를 확인하고 필요할 때 삭제합니다.



신고·제재 — 접수된 신고를 검토·해결·기각한다

신고·제재에서는 접수된 신고를 검토해 해결하거나 기각하고, 필요하면 사용자 활성 상태를 바꾸거나 게시물을 지웁니다. v0.1.31 은 신고 유형·우선순위·SLA를 사용자 정의하는 설정을 제공하지 않으므로, 기관별 기준과 escalation은 별도 운영 정책으로 관리하고 검토 메모에 판단 근거를 남기세요. 반복 패턴은 관찰하되 자동 판단만으로 영구 제재하지 않습니다.

5.3 감사 로그와 실패 이벤트 복구

MOINA
SOCIAL KNOWLEDGE NETWORK

- 플로우
- 탐색
- 검색
- 필스
- 알림
- 포켓
- 모임
- AI

서비스 관리자

- 관리 대시보드
- 사용자 관리
- 콘텐츠 관리
- 신고·제재
- 역할·권한

빠른 이동 Ctrl K

모인 작성

capture-admin
@capture-admin

SERVICE ADMIN

감사 로그

로그인, 관리 설정, 권한과 콘텐츠 조치 이력을 변경 불가능한 기록으로 추적합니다.

실패 이벤트 복구

재시도 한도를 넘긴 알림·비동기 이벤트를 확인하고 안전하게 다시 처리합니다.

새로고침

복구할 실패 이벤트가 없습니다

현재 모든 비동기 이벤트가 정상 처리되고 있습니다.

수행자, 작업, 대상 검색

새로고침

시각	수행자	작업	대상	결과	IP	상세
2026년 9월 11일 오전 05:54	@capture-admin	profile.preferences.update	user:usr_HXY9gWX59PMFwCXH36EGgZO	성공	172.18.0.1	▶ 보기
2026년 9월 11일 오전 05:54	@capture-admin	post.create	post:moin_EoT3iBu0rKQZAgAH5MwkkX24	성공	172.18.0.1	▶ 보기
2026년 9월 11일 오전 05:54	@capture-admin	post.create	post:moin_5P2Uc1VGIMvoGEa0yOZ9yxw-	성공		
2026년 9월 11일 오전 05:54	@capture-admin	moim.create	moim:moim_mgt-1sYXpX7aoTiqk5S1H-fm	성공	172.18.0.1	▶ 보기
2026년 9월 11일 오전 05:54	@capture-admin	auth.login	user:usr_HXY9gWX59PMFwCXH36EGgZO	성공	172.18.0.1	▶ 보기

서비스 관리자

개인 설정과 분리된 운영 영역

감사 로그 — 실패 이벤트 복구 영역과 시각·수행자·작업·대상·결과·IP 기록

감사 로그는 로그인, 관리 설정, 권한과 콘텐츠 조치를 변경 불가능한 기록으로 남기고 수행자, 작업 (`auth.login` , `post.create` , `profile.preferences.update` 등), 대상, 결과와 IP를 함께 보여 줍니다.

Dead Letter로 떨어진 비동기 event는 같은 화면 위쪽 **실패 이벤트 복구**에서 처리합니다.

1. event 종류, 대상, 시도 횟수와 마지막 오류를 확인합니다.
2. PostgreSQL·권한·대상 데이터 같은 원인을 먼저 해결합니다.
3. 재처리를 눌러 대기열로 되돌리고 Outbox 지연과 감사 기록을 확인합니다.

원인을 해결하지 않은 반복 재처리는 피하세요.

5.4 관측

`GET /metrics` 는 Prometheus text 형식으로 Flow·검색 지연, Flow 요청당 SQL 수, Outbox 지연과 실패, DB pool 과 WebSocket 연결 수를 제공합니다. 이 endpoint는 reverse proxy에서 운영 수집망에만 허용하세요. 응답의 `X-Request-ID` 는 JSON 로그의 `request_id` 와 같은 값이므로 장애 추적에 함께 씁니다. 컨테이너 로그는 `docker`

logs (compose 기본 json-file, 10 MiB×5)로 봅니다.

알림 경로에는 안전 장치가 있습니다. LISTEN consumer는 채널이 포화되면 backpressure를 적용하고, 느린 browser socket은 연결을 끊어 최대 30초 backoff로 재연결하게 하며, client는 연결 직후와 60초마다 REST로 미확인 수를 다시 맞춥니다. 일시적인 WebSocket 재연결만으로 알림이 유실됐다고 판단하지 마세요.

5.5 백업과 복구

- Large Object를 포함한 PostgreSQL 전체 backup을 만듭니다. 논리 backup은 blob 포함 옵션 (`pg_dump -b` 등)을 명시합니다.
- 같은 시점의 `MOINA_ENCRYPTION_KEY` 와 현재 이미지 `tar.gz` 를 서로 다른 보안 영역에 보관합니다.
- 복구 훈련에서 미디어·DB backup·원래 key가 함께 유효한지 확인합니다. `v0.1.31` 은 온라인 root key 교체를 제공하지 않습니다.

5.6 업그레이드와 되돌리기

1. release notes와 migration을 검토하고 DB backup을 만듭니다.
2. 서비스 중단 전에 로컬 bootstrap 최고 관리자 로그인을 확인합니다.
3. 새 `tar.gz` 의 SHA256을 확인하고 이미지를 load합니다.
4. staging에서 최대 30분 migration, 로그인, Flow·검색·알림과 rollback을 검증합니다.
5. compose의 image tag를 바꾸고 재시작한 뒤 `/readyz` , 버전과 `/metrics` 를 확인합니다.

적용된 migration의 SHA-256 checksum이 달라지면 서버가 시작을 거부합니다. DB에 현재 binary가 모르는 migration version이 있어도 downgrade guard가 기동을 거부합니다. 과거 SQL이나 `schema_migrations` 를 고치지 말고 DB schema와 맞는 정식 이미지를 쓰세요. 되돌리기는 이전 앱이 새 schema를 읽을 수 있다고 확인한 경우에만 수행합니다.

버전별 주의 사항은 [오프라인 운영 가이드](#)에 정리되어 있습니다. 특히 `v0.1.0` 에서 올라오는 배포는 사설 OIDC·AI host가 자동으로 사설망 허용 목록에 들어가지 않으므로, 업그레이드 뒤 로컬 관리자로 각 정확한 hostname을 전체·사설망 허용 목록에 저장하고 연결 테스트를 다시 실행해야 합니다.

6. 장애 대응

증상	확인할 곳	조치
/readyz 실패	컨테이너 로그, <code>schema_migrations</code>	최대 30분 migration이 진행 중인지, 알 수 없는 migration·downgrade인지, PostgreSQL 계정·권한·checksum 문제인지 구분합니다.
Flow 새로고침이 429	응답 code <code>feed_snapshot_busy</code> , <code>Retry-After: 1</code>	같은 계정의 반복 refresh를 멈추게 안내합니다.
로그인·가입·API 키 요청이 503	응답 code <code>rate_limit_unavailable</code>	PostgreSQL 연결과 <code>rate_limit_buckets</code> migration을 확인합니다.
감사 로그의 Client IP가 이상함	감사 로그의 소켓 IP·Client IP·Proxy Chain	직접 연결하는 Peer의 IP/CIDR이 신뢰 Proxy 목록에 있는지 확인합니다.
OIDC callback 실패	<code>oidc_client_auth_failed</code> , <code>oidc_code_rejected</code>	Issuer·port·discovery·Redirect URI·DNS/CA와 서버 시간을 확인합니다. v0.1.0 업그레이드라면 사설 host를 명시 저장합니다.
AI 응답(SSE)이 끊김	AI 허용 host, reverse proxy 설정	전체·사설망 허용 host와 port, DNS/CA, proxy의 buffering·timeout을 확인합니다.
WebSocket 연결 실패	proxy 설정	<code>Upgrade</code> header 전달, idle timeout, origin 정책을 확인합니다. 느린 client는 재연결과 60초 reconcile로 회복합니다.
Outbox 지연	<code>moina_outbox_lag_seconds</code> , 실패 이벤트	DB lock과 원인을 해결한 뒤 재처리합니다.
대용량 업로드가 중단됨	proxy request timeout·body 제한	서버 기한은 업로드 15분입니다. proxy 값을 최대 업로드 크기에 맞춥니다.
미디어 업로드 거부	응답 code, GET <code>/api/v1/media/config</code>	MIME·파일 byte·개수와 미첨부 100개·512 MiB quota를 확인합니다.
미디어 용량이 계속 증가	정리 로그, Large Object backup	미사용 업로드 정리 시간과 시간당 최대 10,000개 정리 한도를 확인합니다.
복호화 오류	주입된 <code>MOINA_ENCRYPTION_KEY</code>	올바른 key인지 확인하고 임의 교체를 중단합니다.

장애 기록에는 버전, image digest, 발생 시각, X-Request-ID , 화면 오류 code, 관련 감사 event ID와 영향 범위를 남기고 DSN·비밀번호·token·암호화 key는 남기지 않습니다.

7. 보안

기본값 중 배포 전에 반드시 손봐야 하는 것들입니다.

- **bootstrap 비밀번호** — 최초 로그인 직후 화면에서 바꿉니다. 환경변수만 바꾸는 것으로는 이미 만들어진 계정이 바뀌지 않습니다.
- **.env 권한** — `chmod 600 .` 비밀 관리 시스템에서 주입하는 쪽이 더 낫습니다.
- **MOINA_ENCRYPTION_KEY** — DB backup과 다른 보안 영역에 보관합니다.
- **PostgreSQL DSN** — 운영에서는 TLS를 검증하는 `sslmode` 를 씁니다.

외부에 열지 말아야 할 것들입니다.

- **컨테이너 포트 8080** — 기본 compose대로 `127.0.0.1` 에만 bind하고 앞단 TLS proxy를 통해서만 노출합니다.
- **GET /metrics** — 운영 수집망에서만 접근하게 proxy에서 제한합니다.
- **PostgreSQL** — 서비스 호스트에서만 접근하게 방화벽으로 막습니다.

인증과 연동에서 지킬 것들입니다.

- 로컬 최고 관리자 계정을 최소 한 개 유지해 SSO 장애 시 접근 경로를 남깁니다.
- OIDC·AI·SMTP의 허용 host는 정확한 authority만 등록합니다. wildcard·scheme·경로는 넣지 않으며, loopback·link-local·cloud metadata·CGNAT·unspecified·multicast는 항상 차단됩니다.
- 폐쇄망 HTTP는 명시적으로 컨 등록 host에만 허용합니다.
- 방문 추적은 꺼진 채 두는 것이 기본입니다. 커더라도 `'unsafe-inline'` 으로 정책을 풀지 않고 요청별 nonce를 쓰며, 데이터가 밖으로 나가지 않는 Momento 같은 오리진 프록시를 먼저 고릅니다.
- 최소 권한 원칙으로 역할을 나누고, 특히 `audit:read` (조사)와 `outbox:manage` (복구), `settings:manage` (설정)를 서로 다른 역할에 둡니다.
- 컨테이너는 `read-only·non-root·cap_drop: ALL·no-new-privileges` 로 실행합니다. 기본 compose가 이미 그렇게 되어 있으니 임의로 완화하지 마세요.

더 보기

- [사용자 가이드](#) — 화면 사용법(사용자에게 안내할 문서)
- [설정](#) · [오프라인 운영](#) · [보안과 키 관리](#)
- [REST API와 MCP](#) · [OpenAPI 3.1](#)
- [아키텍처](#)